

FACULTAD DE INGENIERÍA

CASO DE ESTUDIO DEL MÓDULO

Coopaburrá: treinta y ocho transferencias que nadie puede probar

SIO0010 · Técnicas Criptográficas

Especialización en Seguridad de la Información de las Organizaciones

SECTOR

Cooperativa financiera
Vigilada por la
Superfinanciera

USO

Las seis sesiones
y el producto final

NATURALEZA

Caso ficticio con fines
exclusivamente docentes

DOCENTE

Nombre

PARTE 1

La organización

Cooperativa Financiera del Aburrá — Coopaburrá nació en 1978 como fondo de empleados de las textileras de Itagüí. En 1997 se convirtió en cooperativa financiera y quedó bajo vigilancia de la Superintendencia Financiera de Colombia. Es la organización sobre la que ustedes trabajarán durante los seis encuentros. Todos los artefactos que produzcan se refieren a ella.

142.000	\$1,4	380
asociados activos	billones en activos	empleados · 24 en tecnología
11	32	20
oficinas en Aburrá y Oriente	cajeros automáticos propios	años del crédito hipotecario más largo

Productos y asociados

Ahorro a la vista, CDT, crédito de consumo, crédito hipotecario hasta a veinte años, tarjeta débito propia y, desde marzo de 2023, una aplicación móvil con transferencias y pagos. La base es mayoritariamente de ingresos medios y bajos: empleados de manufactura, comerciantes y pensionados. **Para buena parte de ellos, Coopaburrá es la única entidad financiera con la que tienen relación.**

Estacionalidad que condiciona cualquier cambio técnico

MOMENTO	QUÉ PASA Y QUÉ IMPLICA
Días 15 y 30	Pago de nómina de las empresas asociadas. La operación se triplica. Ninguna intervención técnica se autoriza esos días ni el día anterior.
Primer trimestre	Asamblea general de asociados en marzo y distribución de excedentes. Alta exposición pública.
Junio y diciembre	Primas. Picos de apertura de CDT y de retiro en cajeros.
Ventana de mantenimiento	Domingos de 1:00 a 5:00 a.m. Es la única franja con indisponibilidad autorizada, y la comparten todas las áreas.

ADVERTENCIA SOBRE LA NATURALEZA DEL CASO

Coopaburrá no existe. Es un caso construido para este módulo. Las cifras, personas, proveedores y documentos son verosímiles y están inspirados en situaciones frecuentes del sector, pero **no corresponden a ninguna entidad, empresa ni persona real**. Cualquier parecido es involuntario.

PARTE 2

Quién es quién

Si su informe propone un cambio, tiene que decir quién lo autoriza, quién lo ejecuta y quién responde después. Estas son las personas disponibles.

PERSONA Y CARGO	DE QUIÉN DEPENDE	QUÉ DECIDE Y QUÉ LE PREOCUPA
Jorge Iván Mesa Presidente del Consejo de Administración	Asamblea	Aprueba presupuesto anual y políticas. Le preocupa la asamblea de marzo y que el caso llegue a la prensa.
Luz Marina Restrepo Gerente general	Consejo	Decide inversiones dentro del presupuesto aprobado. Pidió el diagnóstico. Quiere saber cuánto cuesta y cuánto tarda.
Édison Zapata Gil Jefe de Infraestructura	Gerencia	Responde de hecho por la seguridad, sin que nadie se lo haya asignado formalmente. Lleva 14 años. Conoce todo y no tiene tiempo para nada.
Yeison Cardona Coordinador de Desarrollo	Édison Zapata	Mantiene el portal. Cuatro desarrolladores a cargo. Fue quien escribió el portal en 2019.
Beatriz Elena Cano Oficial de cumplimiento	Gerencia	Dedicada a prevención de lavado de activos. No tiene función de seguridad informática, pero es quien habla con la Superintendencia.
Hernán Betancur Apoderado externo	Contrato	Lleva las demandas de los asociados. Es quien hizo la pregunta que nadie supo responder.
Revisoría fiscal Firma externa	Asamblea	Emite informes semestrales. En 2024 dejó una observación sobre controles de tecnología que no se atendió.
Wílmor Agudelo Ex contratista	—	Montó la autoridad certificadora interna en 2019. No trabaja allí desde 2022. Su computador sigue encendido en el centro de datos.

Lo que la estructura revela

Nadie tiene la función

No existe el cargo de responsable de seguridad de la información. La función la ejerce de hecho el Jefe de Infraestructura, que es juez y parte: opera los sistemas y a la vez tendría que controlarlos. Es el mismo problema de segregación que estudiaron en gestión de riesgos.

Nadie custodia las llaves

En una entidad financiera, las llaves criptográficas deberían tener custodios designados, ceremonias documentadas y doble control. Aquí las llaves las tiene quien las necesitó el día que las necesitó, y en algunos casos ya no trabaja en la cooperativa.

PARTE 3

Qué tiene montado

Inventario tecnológico entregado por la Jefatura de Infraestructura. Es lo único que existe: no hay inventario de llaves ni de certificados.

SISTEMA	OPERADO POR	DETALLE TÉCNICO	NOTAS
Core financiero	NúcleoCoop S.A.S.	Servidor propio en Itagüí. Base de datos relacional, 2,3 TB. Sistema operativo con soporte extendido pagado.	Instalado en 2011. Última actualización mayor en 2021. El contrato no incluye cambios en el esquema de datos.
Portal de asociados	Coopaburrá	Aplicación web propia, escrita en 2019. Servidor web en el mismo centro de datos. Publicado en internet.	Consulta de saldos y extractos. 9.000 sesiones diarias. Lo mantienen cuatro desarrolladores.
Aplicación móvil	Bitlab S.A.S.	Android e iOS. Servidor de aplicación en nube pública. Se conecta al core por un servicio intermedio.	Lanzada en marzo de 2023. 18.000 transacciones diarias; hasta 61.000 los días 15 y 30.
Red de cajeros	Coopaburrá	32 cajeros propios más red aliada. Llaves de comunicación cargadas manualmente.	Puesta en marcha en 2019. El fabricante recomienda rotar llaves cada dos años.
Procesador de tarjetas	Proveedor externo	Autoriza las transacciones de la tarjeta débito. Coopaburrá no almacena el número completo.	Contrato desde 2017. El proveedor exige cumplimiento del estándar de la industria de pagos.
Gestor documental	Coopaburrá	Servidor de archivos. Contratos y pagarés en PDF, organizados por carpetas.	1,1 millones de documentos. Los más antiguos son de 2009.
Respaldos	Coopaburrá	Script programado. Copia diaria a disco externo entre 11:40 p.m. y 2:15 a.m.	Una copia semanal sale en vehículo hacia una bodega en Sabaneta, los viernes.
Correo y directorio	Nube / Coopaburrá	Correo en nube pública. Directorio de usuarios local para los sistemas internos.	380 buzones. No hay segundo factor de autenticación habilitado.

EL DATO QUE CONVIENE RETENER DESDE YA

Coopaburrá **sí usa criptografía en todas partes**: en el portal, en la aplicación, en los cajeros, en los respaldos, en el correo y en el cifrado de disco. El problema del caso no es la ausencia de criptografía. Es que nadie sabe qué algoritmos están en uso, quién tiene las llaves, cuándo se rotan, ni cómo se probaría ante un juez que una operación la autorizó su titular.

PARTE 4

Bajo qué normas opera

Ustedes ya vieron marco legal en el módulo anterior. Aquí está lo que aplica específicamente a esta organización y a este problema.

NORMA O MARCO	QUÉ LE EXIGE A COOPABURRÁ EN MATERIA CRIPTOGRÁFICA
Circular Básica Jurídica Superintendencia Financiera	Requerimientos mínimos de seguridad y calidad en el manejo de información a través de canales de distribución: cifrado de la información confidencial de los clientes en canales, autenticación de los clientes, y registros que permitan reconstruir las operaciones. Es la norma que la Superintendencia va a verificar en la visita.
Ley 527 de 1999	Valor probatorio de los mensajes de datos y de la firma digital. Define qué hace que una firma electrónica sea confiable y en qué condiciones un documento electrónico equivale a uno escrito. Es el eje del hallazgo de los créditos hipotecarios.
Ley 1273 de 2009	Tipifica los delitos informáticos. Es el marco de la denuncia penal por las transferencias no autorizadas, y define qué constituye acceso abusivo y violación de datos personales.
Ley 1266 de 2008	Habeas data financiero. Regula el manejo de la información crediticia de los asociados y su reporte a operadores de información.
Ley 1581 de 2012 y Decreto 1074 de 2015	Protección de datos personales. Deber de adoptar medidas de seguridad sobre los datos de los 142.000 asociados, e inscripción de las bases en el registro nacional.
Estándar de seguridad de la industria de pagos	Exigido por el procesador de tarjetas por contrato, no por ley. Impone requisitos concretos de cifrado, gestión de llaves y rotación para los datos de tarjeta.
Ley 79 de 1988	Régimen cooperativo. Define los órganos de gobierno —asamblea, consejo de administración— que aparecen en el organigrama y que aprueban el presupuesto.

EL DETALLE QUE CAMBIA LA URGENCIA

La Superintendencia Financiera anunció **visita de inspección para septiembre de 2026**. Entre los temas anunciados está la seguridad de los canales digitales. Cualquier hoja de ruta que ustedes propongan tiene que contestar una pregunta incómoda: **qué va a estar listo antes de esa visita y qué no**, y por qué ese orden es defendible.

PARTE 5

Contratos y antecedentes

Lo que dicen los contratos

PROVEEDOR	VIGENCIA	CLÁUSULAS QUE IMPORTAN
Bitlab S.A.S. Aplicación móvil	Hasta el 31 de diciembre de 2026	El alcance contratado es desarrollo y mantenimiento correctivo. No incluye gestión de llaves ni seguridad de la aplicación. El código fuente es propiedad de Coopaburrá, pero está alojado en el repositorio del proveedor. No hay cláusula de auditoría de seguridad.
NúcleoCoop S.A.S. Core financiero	Renovación automática anual	Soporte y actualizaciones. Cualquier cambio en el esquema de la base de datos se cotiza aparte y requiere aprobación del fabricante. Esto condiciona directamente lo que se pueda hacer con el cifrado a nivel de campo.
Procesador de tarjetas	Hasta 2027	Exige cumplimiento del estándar de la industria de pagos y se reserva el derecho de auditar. Coopaburrá nunca ha sido auditada bajo esa cláusula.

Lo que ya había pasado antes

2019	Se crea la autoridad certificadora interna para evitar el costo de certificados comerciales. Se emite el certificado del portal. Se documenta en un correo, no en un procedimiento.
2021	Un proveedor cotiza una infraestructura de llave pública y un módulo de seguridad de hardware por \$240 millones . El consejo no la aprueba: "no hay un problema que lo justifique".
2022	Wílmor Agudelo termina su contrato. Nadie recibe formalmente las llaves ni los procedimientos . Su equipo queda encendido.
2023	Se lanza la aplicación móvil en cuatro meses. La decisión sobre el esquema de firma se toma "para agilizar la salida a producción".
2024	La revisoría fiscal deja una observación: "no se evidencian controles formales sobre la administración de claves de acceso y cifrado" . Se responde que se atenderá en el plan de 2025. No se atendió.
2025	Se aprueba un presupuesto de seguridad de \$180 millones para 2026, sin destinación específica.

LO QUE HAY QUE VER AQUÍ

El incidente de 2026 no fue una sorpresa: **fue anunciado dos veces**, en 2021 por un proveedor y en 2024 por la revisoría fiscal. Lo que faltó no fue información técnica, sino alguien con la autoridad y el argumento para convertir esa información en una decisión de inversión. Ese argumento es, literalmente, lo que ustedes tienen que construir.

PARTE 6

Lo que pasó

Cronología reconstruida por la Jefatura de Infraestructura a petición del comité de riesgos.

12 de enero	Una asociada de la oficina de Itagüí reclama en ventanilla: su extracto registra una transferencia de \$1.850.000 que afirma no haber hecho. Se radica como reclamo ordinario y se le pide esperar quince días hábiles.
19 de enero	Se acumulan nueve reclamos del mismo tipo. Todos son usuarios de la aplicación móvil. Todas las transferencias salieron hacia tres cuentas de otra entidad, en montos entre \$900.000 y \$2.400.000.
23 de enero	Tecnología revisa los registros del servidor de la aplicación. Las operaciones aparecen correctamente autenticadas y dentro de horario normal . Ninguna alerta se disparó.
27 de enero	Un ingeniero de Bitlab informa, primero de manera verbal y luego por correo, que la aplicación firma cada operación con una clave compartida incrustada en el código, igual para todos los usuarios desde 2023.
30 de enero	Se bloquean preventivamente las transferencias por la aplicación hacia entidades externas. El canal más usado queda degradado en plena quincena.
2 de febrero	Los reclamos llegan a 38 , por \$71.400.000 . La cooperativa decide reintegrar el dinero a los asociados mientras se investiga, para contener el daño reputacional. Cuatro asociados anuncian demanda de todos modos.
5 de febrero	El apoderado pregunta en comité cómo se prueba que las operaciones no fueron hechas por los asociados. Nadie sabe responder . Queda en acta.
9 de febrero	El comité de riesgos ordena un diagnóstico criptográfico completo y contrata asesoría externa. Ahí entran ustedes .
11 de febrero	Infraestructura entrega el "inventario de llaves" solicitado: cinco líneas en un correo.

EL PROBLEMA DE FONDO

La cooperativa no puede demostrar nada en ninguna de las dos direcciones. No puede probar que las operaciones fueron fraudulentas, y tampoco puede probar que fueron legítimas. Los registros existen, pero **cualquier persona con acceso al servidor pudo haberlos modificado sin dejar rastro**, y la clave con la que la aplicación firma las operaciones es la misma para los 142.000 asociados y viaja dentro del programa que cualquiera descarga de la tienda.

La pregunta que gobierna el módulo

Coopaburrá cifra. Cifra el disco, cifra el canal, cifra los respaldos. **¿Por qué, entonces, no puede probar absolutamente nada?**

PARTE 7 · 1 DE 2

Los ocho hallazgos del diagnóstico

Levantados en las dos semanas siguientes. Cada uno se trabaja en una sesión distinta del módulo.

H1 Contraseñas del portal con SHA-1 y una sal única para toda la base

Sesión 3

La tabla de usuarios guarda el resumen SHA-1 de la contraseña concatenada con una cadena fija, **la misma para los 142.000 asociados**. La cadena está en el código fuente, versionado en un repositorio al que tienen acceso once personas. No hay función de derivación ni factor de trabajo. La política de contraseñas exige seis caracteres y no obliga a cambiarlas.

H2 La aplicación firma las operaciones con una llave incrustada en el código

Sesión 3 y 4

Cada transferencia se acompaña de un código de autenticación HMAC-SHA256 calculado con una llave compartida provisionada al compilar. Es **idéntica para todos los usuarios y para todas las versiones desde 2023**. Quien la extraiga puede producir operaciones que el servidor acepta como auténticas. No hay firma por usuario, ni segundo factor, ni vinculación con el dispositivo. **Este es el hallazgo que hace imposible el no repudio.**

H3 Cifrado de disco completo confundido con protección de datos

Sesión 2

Los servidores tienen cifrado de disco completo y por eso el informe de 2019 declaró el dato "protegido". Pero el disco solo está cifrado **cuando el servidor está apagado**. Con el servidor encendido, cualquier consulta devuelve cédula, saldo y movimientos en claro. No hay cifrado a nivel de campo, ni enmascaramiento, ni control de quién consulta qué. Once personas tienen acceso de lectura a la base.

H4 Los respaldos están cifrados con una llave guardada junto a los respaldos

Sesión 2 y 6

La rutina cifra el archivo con AES y deja la llave en un archivo de texto **en el mismo directorio**, para que el script restaure sin intervención humana. Además la llave se pasa como argumento en la línea de comandos, así que queda visible para cualquier usuario que liste los procesos. La copia semanal que viaja a Sabaneta lleva las dos cosas en el mismo disco, **en el carro de un mensajero**.

PARTE 7 · 2 DE 2

Los ocho hallazgos del diagnóstico

H5 El certificado del portal lo emite una autoridad interna cuya llave privada está en un escritorio

Sesión 5

La autoridad certificadora interna se creó en 2019 para no pagar certificados. Su llave privada está en el computador de escritorio de un contratista que no trabaja allí desde 2022; el equipo sigue encendido en un rincón del centro de datos, sin contraseña de arranque. **El certificado del portal vence el 14 de junio de 2026** y nadie sabe quién lo renueva. Los navegadores muestran advertencia a los asociados, que ya se acostumbraron a aceptarla.

H6 Las llaves de los cajeros se cargaron en 2019 y nunca se rotaron

Sesión 6

Las llaves de comunicación de los 32 cajeros propios se cargaron manualmente en la puesta en marcha. El procedimiento lo ejecutaron dos personas, una de las cuales ya no trabaja allí. **No hay registro de ceremonia, ni custodios designados, ni doble control, ni fecha de rotación.** El fabricante recomienda rotarlas cada dos años. Van siete.

H7 Los créditos hipotecarios se firman con una imagen escaneada y se guardan veinte años

Sesión 4 y 6

El contrato y el pagaré se generan en PDF, se les inserta la imagen de la firma capturada en una tableta, y se archivan en el gestor documental. **No hay firma digital, ni sello de tiempo, ni entidad de certificación.** Estos documentos deben conservar valor probatorio durante toda la vigencia del crédito, que llega a veinte años. Es el dato de vida más larga de la organización, y el que conecta este caso con la transición criptográfica que viene.

H8 No existe inventario criptográfico

Sesión 1

Nadie puede responder cuántas llaves existen, qué algoritmos están en uso, en qué versiones, quién las custodia ni cuándo vencen. **Los siete hallazgos anteriores se descubrieron por separado y por casualidad**, durante dos semanas de diagnóstico. Este es el primero que hay que resolver, porque sin él no se puede priorizar ningún otro ni responderle a la Superintendencia.

CÓMO SE RELACIONAN

H1 y H2 explican por qué el fraude fue posible. H2 y H7 explican por qué no se puede probar nada ante un juez. H3 y H4 explican por qué una filtración sería total. H5 y H6 son bombas de tiempo con fecha conocida. **Y H8 explica por qué nadie lo vio venir.**

PARTE 8

Evidencia técnica recogida

Salidas reales del diagnóstico. Las van a necesitar en los laboratorios.

EVIDENCIA A · REVISIÓN DEL CANAL SEGURO DEL PORTAL, 10 DE FEBRERO

Protocolos habilitados: TLS 1.0, TLS 1.1, TLS 1.2

Suites negociadas: incluyen intercambio de llave RSA sin confidencialidad futura

Certificado: RSA 2048 bits, firmado con SHA-256

Emisor: "Coopaburra Root CA 2019"

Vigencia: 14 de junio de 2023 al 14 de junio de 2026

Cadena: no reconocida por navegadores; advertencia en cada visita

Para la sesión 5. Noten que el certificado en sí no es débil: RSA 2048 con SHA-256 es aceptable. El problema es quién lo emitió, quién tiene esa llave y qué pasa en junio.

EVIDENCIA B · MUESTRA DE LA TABLA DE USUARIOS DEL PORTAL, ANONIMIZADA

id | usuario | hash

1 | usuario_a | 5baa61e4c9b93f3f0682250b6cf8331b7ee68fd8

2 | usuario_b | 7c4a8d09ca3762af61e59520943dc26494f8941b

3 | usuario_c | 5baa61e4c9b93f3f0682250b6cf8331b7ee68fd8

sal declarada por la fábrica de software: constante "c00pab2019" para todos los registros

Para la sesión 3. Dos observaciones saltan de inmediato: los resúmenes tienen 40 caracteres hexadecimales, y dos usuarios distintos tienen el mismo. Ambas cosas dicen algo grave. Y una advertencia: la sal que aparece en la muestra es lo que la fábrica de software **declara en su documentación**, no un hecho verificado por el diagnóstico. Comprobar si de verdad se aplicó, y con qué orden, es parte del trabajo de la sesión 3.

EVIDENCIA C · LÍNEA DEL SCRIPT DE RESPALDO, TOMADA DEL PROGRAMADOR DE TAREAS

```
openssl enc -aes-256-cbc -in respaldo_diario.sql -out respaldo_diario.enc \
-k $(cat /opt/backup/llave.txt)
```

Para la sesión 2. Aquí hay al menos tres problemas distintos, y solo uno es que la llave esté en un archivo de texto. Los otros dos son sobre cómo se deriva la llave y sobre qué hace la opción utilizada.

EVIDENCIA D · FRAGMENTO DEL CÓDIGO DE LA APLICACIÓN MÓVIL, OBTENIDO AL DESCOMPILAR EL PAQUETE PÚBLICO

```
private static final String SIGNING_KEY = "Cb4rr4-2023-HMAC-k3y";
// firma de operaciones: HMAC-SHA256(SIGNING_KEY, payload)
```

Para las sesiones 3 y 4. El paquete se descarga de la tienda pública. Descompilarlo no requiere herramientas especiales. La llave lleva ahí desde marzo de 2023.

PARTE 9

Los documentos del expediente

Léanlos con atención: en ellos está casi todo el problema.

DOCUMENTO 1 · ACTA DEL COMITÉ DE RIESGOS, 9 DE FEBRERO DE 2026, EXTRACTO

«...el Jefe de Infraestructura informa que los registros del servidor de aplicaciones muestran las operaciones reclamadas como correctamente autenticadas. Ante la pregunta del apoderado sobre si dichos registros pueden ser alterados, responde que el acceso al servidor está restringido a cuatro personas del área. El apoderado insiste en si existe forma técnica de demostrar que no fueron alterados. No se obtiene respuesta. Se ordena diagnóstico criptográfico con apoyo externo...»

La pregunta del abogado no es sobre control de acceso. Es sobre integridad demostrable, que es otra cosa.

DOCUMENTO 2 · CORREO DE BITLAB S.A.S., 27 DE ENERO DE 2026, EXTRACTO

«...confirmamos que el esquema de firma de operaciones utiliza HMAC-SHA256 con una clave compartida provisionada en tiempo de compilación. Esta decisión se tomó en 2023 de común acuerdo para evitar el costo de una infraestructura de llave pública y agilizar la salida a producción. El alcance contratado no incluía gestión de llaves...»

El algoritmo es correcto y moderno. HMAC-SHA256 no está roto. Lo que está roto es cómo se administra la llave. Esta distinción es el corazón del módulo.

DOCUMENTO 3 · POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN, 2019, ARTÍCULO 14, COMPLETO

«Artículo 14. Cifrado. Toda información confidencial de la Cooperativa deberá ser cifrada en reposo y en tránsito utilizando algoritmos de reconocida robustez. La Jefatura de Infraestructura velará por el cumplimiento de esta disposición.»

Es el artículo completo, no un extracto. No define qué algoritmos, ni longitudes, ni custodios, ni rotación, ni qué pasa cuando alguien se va. Es una política que no se puede auditar.

DOCUMENTO 4 · INFORME DE REVISORÍA FISCAL, SEGUNDO SEMESTRE DE 2024, OBSERVACIÓN 7

«No se evidencian controles formales sobre la administración de claves de acceso y cifrado, ni procedimientos documentados para su custodia y renovación. Se recomienda a la administración establecerlos.» — Respuesta de la administración: «Se atenderá dentro del plan de trabajo de la vigencia 2025.»

La observación existía dieciocho meses antes del incidente. La respuesta también.

DOCUMENTO 5 · INVENTARIO DE LLAVES ENTREGADO POR INFRAESTRUCTURA, 11 DE FEBRERO DE 2026, ÍNTEGRO

«Certificado del portal (vence en junio). Llaves de cajeros (las cargó el proveedor). Llave de respaldos (está en el servidor). Certificado del correo (lo renueva el proveedor de correo). Pendiente confirmar si la aplicación móvil usa llaves.»

Cinco líneas escritas en un correo. Este es, literalmente, todo el inventario criptográfico de una entidad vigilada que administra 142.000 asociados y \$1,4 billones.

PARTE 10

Con qué cuentan y contra qué corren

Sin estos dos cuadros no se puede priorizar nada, y priorizar es lo que se evalúa.

Recursos disponibles

RECURSO	DISPONIBLE	CONDICIONES
Presupuesto de seguridad 2026	\$180.000.000	Aprobado sin destinación específica. Ejecutable durante la vigencia. Ampliable solo por el consejo, que sesiona mensualmente.
Personal de tecnología	24 personas	Ninguna dedicada a seguridad. Liberar a alguien implica dejar de hacer otra cosa, y hay que decir cuál.
Ventana de indisponibilidad	Domingos 1:00 a 5:00 a.m.	Cuatro horas semanales, compartidas con todas las áreas. Nunca los días 14, 15, 29 y 30.
Proveedor de la aplicación	Contrato vigente	Cualquier cambio de alcance se cotiza aparte. El contrato vence el 31 de diciembre de 2026, lo que abre una oportunidad de renegociación.
Proveedor del core	Contrato vigente	Cambios en el esquema de datos se cotizan y requieren su aprobación. Los tiempos del fabricante son de meses.

Fechas que condicionan la hoja de ruta

FECHA	QUÉ OCURRE
Marzo de 2026	Asamblea general de asociados. El caso puede hacerse público.
8 de abril de 2026	Próxima sesión del comité de riesgos. Es la fecha en que ustedes presentan.
14 de junio de 2026	Vence el certificado del portal. Si no se renueva, el portal deja de estar disponible en condiciones aceptables.
Septiembre de 2026	Visita de inspección de la Superintendencia Financiera , con foco anunciado en seguridad de canales digitales.
31 de diciembre de 2026	Vence el contrato con la fábrica de software.
2039	Vence el crédito hipotecario más largo firmado este año. Sus documentos deben seguir siendo probatorios hasta entonces.

PARTE 11

Lo que se espera de ustedes

El comité de riesgos los contrató para responder tres preguntas. Las seis sesiones están ordenadas para que al final puedan contestarlas con fundamento, y las presentarán el 8 de abril.

- 1 **¿Qué criptografía tiene hoy Coopaburrá y en qué estado está?** Es el inventario criptográfico. Sin él no hay diagnóstico posible, y es lo primero que van a construir.
- 2 **¿Qué hay que cambiar, en qué orden y por qué ese orden?** Con \$180 millones, cuatro horas de ventana semanal y una visita de la Superintendencia en septiembre. Priorizar es el ejercicio, y ya tienen el método del módulo de riesgos.
- 3 **¿Cómo se demuestra, ante un juez, que una operación la autorizó su titular?** Es la pregunta que dejó sin respuesta el comité. Involucra firma digital, sellado de tiempo y la Ley 527 de 1999.

El producto final

Un **informe de aseguramiento criptográfico de Coopaburrá**, construido por partes. Cada entrega parcial se realimenta antes de la siguiente.

PARTE	ENTREGABLE	SE ENTREGA	HALLAZGOS
1	Inventario criptográfico de Coopaburrá	Sesión 2	H8, base de todo
2	Protección de datos en reposo y en respaldos	Sesión 3	H3, H4
3	Rediseño de contraseñas y de la firma de operaciones	Sesión 4	H1, H2
4	Plan de certificados y política de gestión de llaves	Sesión 5	H5, H6
5	Valor probatorio de los créditos a veinte años	Sesión 6	H7
6	Hoja de ruta priorizada y sustentación ante el comité	Sesión 6	Todos

UNA ADVERTENCIA SOBRE EL ENFOQUE

La tentación va a ser resolver el caso a punta de algoritmos: cambiar SHA-1 por Argon2, poner TLS 1.3, comprar un módulo de hardware. Eso es necesario pero es la parte fácil. **Lo que el comité necesita es saber quién responde por cada llave, cómo se prueba lo que se afirma y en qué orden se invierten \$180 millones.** Un informe que solo recomiende algoritmos no aprueba.

PARTE 12

Reglas de trabajo y glosario

- 1 Lo que no está en el caso, ustedes lo deciden y lo declaran.** Formulen el supuesto, escríbanlo explícitamente y sigan. Un informe profesional declara sus supuestos; no inventa certezas.
- 2 Toda afirmación técnica se sustenta** con norma, guía o publicación verificable, citada por número y versión. "Es una buena práctica" no es una fuente.
- 3 Todo cambio propuesto tiene costo, plazo y responsable**, y el responsable tiene que ser una de las personas de la Parte 2.
- 4 Equipos de tres**, conformados en la sesión 1, sin cambios posteriores.
- 5 El caso es ficticio pero se trata como confidencial.** No lo publiquen ni lo carguen en servicios abiertos de terceros.

Glosario del sector

TÉRMINO	QUÉ SIGNIFICA AQUÍ
Asociado	El equivalente al cliente en una cooperativa. Además de usar los servicios, es dueño: aporta capital y vota en la asamblea.
Core financiero	El sistema central donde viven las cuentas, los créditos y la contabilidad. Todo lo demás se conecta a él.
CDT	Certificado de depósito a término. Un ahorro a plazo fijo.
Consejo de Administración	Órgano de gobierno elegido por la asamblea. Aprueba presupuesto y políticas. Es a quien hay que convencer para ampliar recursos.
Revisoría fiscal	Control externo obligatorio que responde ante la asamblea, no ante la gerencia. Sus observaciones quedan por escrito.
Ceremonia de llaves	Procedimiento formal y documentado para generar o cargar llaves criptográficas, con custodios, testigos y acta. En Coopaburrá no existe.
Custodio	Persona designada que responde por una llave o por una parte de ella. Implica que haya al menos dos y que ninguna pueda actuar sola.

LO QUE VAN A PODER DECIR AL TERMINAR

Que saben leer una organización y decir dónde está su criptografía, en qué estado, quién responde por ella y qué hay que hacer primero, con costo y plazo. Eso es exactamente lo que le faltaba a Coopaburrá el 5 de febrero, cuando el abogado preguntó cómo se prueba y nadie supo responder.

Elaborado por · Docente del módulo

Recibido por · Estudiante y fecha